IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Building an Effective Internal IT Audit Function

Contents

- The audit department's real mission.
- The concept of independence and how to avoid misusing it.
- How to add value beyond formal audits via consulting and early involvement.
- How to enhance effectiveness by building relationships.
- The role of the information technology (IT) audit and how to choose the correct focus.
- How to build and maintain an effective IT audit team.

Audit Department Issues

- Many audit departments spend their existence in adversarial relationships with the rest of the company.
- Reporting issues accomplishes nothing, except to make people look bad, get them fired, and create **hatred of auditors**.
- The real value comes when issues are addressed and problems are solved.

Audit Department Issues

- The real mission of the internal audit department is to help improve the state of internal controls. This is accomplished by performing audits and reporting the results, but these acts provide no value in and of themselves.
- They provide value only when the internal control issues are resolved.
- Requires a shift in focus from "reporting" to "improving."

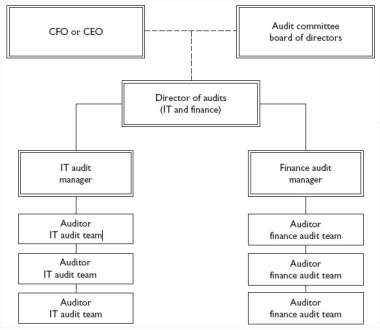
Audit Department Mission

- To provide independent assurance to the audit committee (and senior management) that internal controls are in place at the company and are functioning effectively.
- To improve the state of internal controls at the company by promoting internal controls and by helping the company identify control weaknesses and develop cost-effective solutions for addressing those weaknesses.

Independence: The Great Myth

- Webster : "not influenced or controlled by others"
- Auditors work in the same building as their fellow employees forming relationships outside the audit department.
- Success of company is of prime interest to the auditors.
- Audit departments include people who have joined the department from other areas in the company or plan to rotate out of the audit department.
- Auditor's relationship with the board of directors: Bury issues and believe that he will be allowed to "do the right thing".
- The bottom line: As an auditor, you work for the company and report to its management; therefore, you are *not* independent.

Audit team reporting structure



Consulting and Early Involvement

- Unfortunately, many auditors refuse to provide guidance and input to teams that are developing new systems or processes.
- Auditors can't provide input on the controls within the system because if they do so they'll no longer be independent. They say, "How can you audit something if you've already signed off on the controls?" (utter nonsense)
- The auditor shouldn't be afraid to brainstorm about the controls with the team. However, this should not include actually executing the control, writing the code for implementing it, or configuring the system.
- Auditor should provide as much input as possible regarding what the control should look like.

Four Methods for Consulting

- • Early involvement
- • Informal audits
- • Knowledge sharing
- • Self-assessments

Early involvement

- Once you've created a system, tested it, and implemented it, it is much more expensive to go back and change it than if you had done it right the first time.
- Ask to be part of the sign-off group
- There is the possibility that you will make a mistake and sign off on the project; even though the system has internal control weaknesses, but that's a chance you have to take.
- You should not indicate that internal controls are not applicable to the system and refuse to participate; instead, you can provide some high-level guidance and be done with the project for all intents and purposes.

Informal Audits

- You'll likely never go to the audit committee and report that one of the top fifteen risks that you need to review for the year is a tiny data center in a remote location supporting a small handful of people performing a less-than-critical business process.
- Does this mean that you should never understand the risks at that site?
- The *informal audit* is the mechanism to use.
- Remove the constraints of documenting their work in detailed work papers. Forget about taking large representative samples. Let the auditors act as consultants.
- Auditors are able to accomplish in a short time when released from the shackles of the normal audit process

Informal Audits - basic steps

1. Audit department agrees on timing and scope of the informal review with the people who are to be audited.
2. Auditor creates a checklist of areas that needs review.
3. The auditor executes those steps, keeping notes as needed but not creating work papers for review.
4. At the end, auditor compiles all concerns from review.
5. Conduct a debriefing meeting with people audited to discuss issues, their seriousness, and fixing issues.
6. Auditor documents final list of concerns, along with relevant thoughts on resolving them, in a memo. This memo does not need to include due dates.
7. The auditor issues the memo and archives it electronically for future reference.

Knowledge Sharing

- As an internal auditor, you have a unique blend of knowledge of the company and expertise in internal controls. You must be creative in finding new ways to share knowledge with the rest of the company.
- Audit department should have its own website.
- Posting control guidelines on your website empowers groups expecting an audit.
- Posting Common Issues, Best Practices, and Innovative Solutions.
- Post info about audit tools (vulnerability scanning etc.) that you use in audits, this enables groups to self assess their controls.

Examples

- University of Pennsylvania
  - By failing to prepare, you are preparing to fail - BEN FRANKLIN
  - Office of internal audit
    - http://www.upenn.edu/oacp/audit/index.html
  - Details of internal control
    - https://oacp.upenn.edu/audit/audit101/internal-controls-guidance/
  - SBP:
    - Guidelines on Internal Controls (Confidential document)

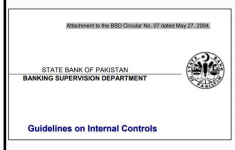
University of Pennsylvania



University of Pennsylvania



SBP - Guidelines on Internal Controls



(Confidential document)

		Title	Page No.
1		**Introduction**	1
	1.1	Objectives of Internal Controls	
2		**Controls Principles**	3
3		**Components of Internal Controls**	4
	3.1	Control Environment	
	3.2	Risk Assessment & Management	
	3.3	Instituting Controls	
	3.4	Accounting, Information & Communication Systems	
	3.5	Self-Assessment & Monitoring	
4		**Responsibilities**	8
	4.1	Board of Directors	
	4.2	Management	
	4.3	Internal Auditor	
	4.4	External Auditor	
	4.5	Regulator	
5		**Implementation of Internal Controls**	10
6		**Evaluation of Internal Controls**	11
	6.1	Process of Evaluation of Internal Controls	
	6.2	Communication of Weaknesses	
7		**Reporting of Internal Controls**	13
		Annexure	15

Self-Assessments

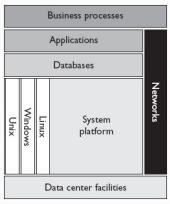
- Facilitating an organization in assessing itself.
- Known as control self-assessment (CSA) model.
- This could be as simple as walking through your control guidelines.

Relationship Building: Partnering vs. Policing

- An effective internal audit department considers the audit to be a partnership with fellow employees and not a policing function.
- Following are some basic steps that you can take to start the journey:
  - Be intentional about regular updates and meetings with IT management.
  - Establish audit liaisons with different IT organizations.
  - Get yourself invited to key meetings.
  - Cultivate an attitude of collaboration and cooperation.
  - Implement job swaps with the IT organization.
  - Involve the IT organization in IT audit hiring decisions.

The Role of the IT Audit Team

- • Application auditors
- • Data extraction and analysis specialists
- • IT auditors



Potential auditing subject areas

- **Data center facilities** This, quite simply, is the physical building and data center housing the computer equipment on which the system in question resides.
- **Networks** This allows other systems and users to communicate with the system in question when they do not have physical access to it. This layer
- includes basic networking devices such as firewalls, switches, and routers.
- **System platform** This provides the basic operating environment on which the higher level application runs. Examples are operating systems such as
- Unix, Linux, and Windows.

- **Databases** This tool organizes and provides access to the data being run by the end application.
- **Applications** This is the end application, which actually is seen and accessed by the end user. This could be an enterprise resource planning (ERP) application providing basic business functions, an e-mail application, or a system that allows conference rooms to be scheduled.

Application Auditors

- Focus almost solely on the application layer.
- Ensuring that access is properly controlled and that segregation of duties issues do not exist.
- Ensuring unauthorized application changes can't occur.
- Ensuring controls are in place to ensure the integrity of data.

Data Extraction & Analysis Specialists

- Experts of data extraction and analysis tools, such as Audit Command Language (ACL).
- Developing analytics that allow for continuous monitoring for evidence of fraud, internal control violations, policy noncompliance, and other abuses.
- This tutorial teaches you how to use audit command language (ACL) to detect ghost names in payroll.
  - https://www.youtube.com/watch?v=FObE7i9GsDI

IT Auditors

- The third model (IT auditors) is critical for performing thorough and effective IT auditing because it ensures that **all layers are being** covered and that they are being covered by the people with the highest level of subject matter knowledge.

Forming and Maintaining an Effective IT Audit Team

- **Career IT Auditors**
- Sources for Career IT Auditors
  - People with Internal IT Audit Experience at Other Companies
  - People with External IT Audit Experience
  - College Hires
- **IT Professionals**
- Sources for IT Professionals as Auditors
  - Technical Professionals from Within Your Company
  - Technical Professionals from Outside Your Company
  - College Hires

Key Traits of a Successful IT Auditor

- *Ability to dig into technical details without getting lost in the details.*
- *Analytical skills.*
- *Communication skills (both written and oral).*
- *Ability to learn the key concepts of new technologies quickly and identify key risk points within those technologies.*
- *Willingness not to be touching a specific technology daily.*
- *Build trust-based relationships with their customers.*

Selling Points for Recruiting IT Professionals into IT Audit

- *Exposure to a wide variety of technologies*
- *Opportunity to work with many levels of management.*
- *Broad view of the company and other IT groups*
- *Opportunity to lead projects.*

Maintaining Expertise

- **Co-sourcing**
- **Sources of Learning**
  - Formal Training
  - Research Time
  - Specialization
- **Knowledge Sharing After Training**
  - Certifications
  - Job Swaps with the IT Organization
- **Combining Options and Maintaining Skills**

Relationship with External Auditors

- May be viewed as an intrusion and an annoyance.
- Must be a healthy working relationship between the internal and external auditors.
- Keep the other informed of their activities.
- Encourage the external auditors to review the internal auditors' work prior to speaking with your customers (customer : organization demanding audit from an external auditor).